

Apex University of Technology
Information Security Policy: Staff Security Awareness
Guide

(Ref Standard: ISO/IEC 27001:2022 Control A.6.3)

Document ID	POL-01
Version	1.0
Target Audience	All Academic, Administrative, and Support Staff
Approved By:	Information Security Governance Board

Section 1: Device Safety & Login Rules

Why this rule exists: To stop unauthorized people from seeing private student files, changing grades, or stealing unreleased exam papers.

- **Rule 1.1 (Automatic Screen Locks):** All computers and laptops used for university work must be set to lock their screens automatically if they are left empty for 10 minutes.
- **Rule 1.2 (Leaving Devices Alone):** A device may never be left alone in a public space like a coffee shop or classroom. Screens must be manually locked every single time you step away from your desk.
- **Rule 1.3 (Using Login Security Codes):** All staff must use a secondary security code on their mobile phones (like a banking app code) every time they log into university systems.

Section 2: Financial System Protections (Fixes the Tuition Fraud Risk)

Why this rule exists: To stop scammers from stealing university funds or tricking parents into paying student fees into fake bank accounts.

- **Rule 2.1 (Two-Person Approval):** No single employee is allowed to change or save the university's banking details or student invoice templates on their own.
- **Rule 2.2 (The Double-Check Rule):** Any change to bank details must be entered into the system by one staff member and approved by a second authorized manager before it is saved.
- **Rule 2.3 (Checking Email Requests):** If a supplier emails you to change their payment details, you must call them using a trusted phone number to check if the request is real before changing anything in the system.

Section 3: Email Safety & Phishing Protection (Fixes the HR Risk)

Why this rule exists: To stop hackers from using fake emails to steal private staff employment contracts, salaries, or medical information.

- **Rule 3.1 (Check the Sender's Address):** Always look closely at the sender's full email address before clicking links or opening attachments. Scammers often use fake email addresses that look very similar to real ones.
- **Rule 3.2 (Watch for Warning Banners):** Always pay attention to the bright yellow warning banner on emails that come from outside the university. Treat any external email that asks for passwords or private info as a danger.
- **Rule 3.3 (Report Strange Messages):** If an email looks unusual, pressures you to act fast, or asks for your password, do not reply. Forward it immediately to it-security@apextech.edu so the team can block it.

Section 4: Enforcement & Consequences

Why this rule exists: To make sure all employees take data safety seriously.

- **Rule 4.1 (Mandatory Reading):** All new and existing university staff must read and sign this safety guide once a year.
- **Rule 4.2 (Consequences):** If an employee intentionally breaks these rules (like sharing their login password or ignoring the two-person finance rule), they will face formal disciplinary action or retraining.

Section 5: Emergency Contacts & Support

Why this rule exists: To give staff an immediate place to get help if they make a mistake.

- **IT Security Helpdesk:** For general questions about setting up your 10-minute screen lock or phone security codes, email it-support@apextech.edu
- **Incident Reporting:** If you accidentally clicked a suspicious link or think your university password was stolen, call the Security Hotline immediately at Ext. 4444